

INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

Week 2 Practical Laboratory

Developing Security Policies and Procedures

NexusTech Solutions — Policy Overhaul Simulation

By

Miracle Nwadiaru

C11/26/CGRCE/17587

INTRODUCTION

NexusTech Solutions is a rapidly growing software development company that specializes in cloud-based Enterprise Resource Planning (ERP) systems. The company has grown from 50 to 250 employees and now serves clients in sensitive sectors such as financial services and healthcare. This growth has increased the amount and sensitivity of information handled by the organization and has also created a greater need for consistent security governance.

At present, NexusTech still relies on a five-year-old document called the IT Rules. The document contains a mixture of high-level security requirements, technical instructions and general recommendations. As a result, employees may not clearly understand what is mandatory, what is recommended and what they are actually expected to do. The situation has also created inconsistent practices, unclear accountability and compliance gaps. The CEO, Marcus Vance, has therefore directed the development of a formal and maintainable information security policy framework.

EVIDENCE BUNDLE 1: SECURITY POLICY HIERARCHY

Task 1: Establishing the Security Policy Hierarchy

1.1 Hierarchy Definition

Document Type	Purpose	Authority	Mandatory/Recommended	Level of detail
Policy	Defines the organization's overall position, requirements and management intent regarding security.	Senior management/executive management	Mandatory	High-level; explains what must be achieved and why
Standard	Defines specific minimum security requirements needed to support a policy.	Management/security authority	Mandatory	More specific than a policy, it defines minimum requirements

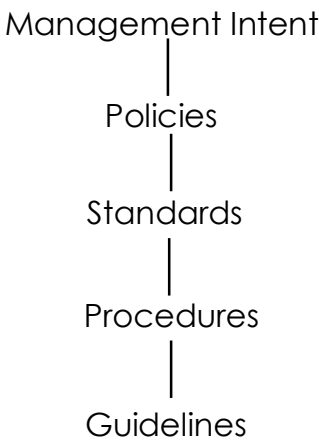
Guideline	Provides recommended approaches and good practices for meeting security objectives.	Security/technical function	Recommended	General practical advice; explains preferred approaches
Procedure	Provides step-by-step instructions for carrying out a specific activity.	Process or system owner	Mandatory where applicable	Detailed; explains how a task should be performed

1.2 Categorization of the Eight Statements

S/N	Statement	Categorization	Justification
1	All NexusTech employees must use MFA when accessing the corporate network remotely	Policy	This establishes a mandatory organizational security requirement without explaining how MFA is technically configured.
2	Download the Authenticator app, scan the QR code and enter the six-digit verification code.	Procedure	It provides sequential instructions explaining exactly how to configure MFA.
3	Developers are recommended to use parameterised queries to reduce SQL injection risk.	Guideline	The wording recommends a security practice but does not make it mandatory.
4	NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.	Policy	This expresses management's high-level security commitment and overall security objective.
5	Corporate laptops must have full-disk encryption using BitLocker or File Vault.	Standard	It establishes a specific mandatory technical requirement that supports a broader security policy.

6	Employees should avoid public, unsecured Wi-Fi networks when travelling.	Guideline	The statement provides recommended behavior rather than an enforceable minimum requirement.
7	Employees must immediately contact the IT Helpdesk at extension 5555 following a suspected security breach.	Policy	It establishes a mandatory incident-reporting requirement
8	Passwords must be at least 14 characters and contain uppercase, lowercase, number and special character.	Standard	It defines specific minimum password requirements that support an access-control or authentication policy.

1.3 Security Policy Hierarchy Diagram



EVIDENCE BUNDLE 2: ACCEPTABLE USE POLICY

Task 2: NexusTech Solutions Acceptable Use Policy

2.1 Document Control

Field	Details
Policy Title	Acceptable Use Policy
Version	1.0

Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, CEO
Effective Date	14 th September, 2026.
Review Date	13 th September, 2027
Status	Approved

2.2 Purpose

The purpose of this Acceptable Use Policy (AUP) is to establish clear rules for the appropriate and responsible use of NexusTech Solutions' information technology resources. The policy is intended to protect company information, client information, systems and networks from misuse, unauthorized access, malware, data loss and other security threats.

The policy also provides employees with a clear understanding of what constitutes acceptable and unacceptable use of company technology. This is particularly important because NexusTech has grown significantly and now handles information belonging to financial and healthcare clients.

2.3 Scope

This policy applies to all NexusTech employees, contractors, consultants, temporary staff and other authorized users who access company information resources.

It covers company-owned or company-managed computers, laptops, mobile devices, networks, applications, cloud services, email systems, internet access and information stored or processed using NexusTech resources.

The policy also applies when employees access NexusTech information remotely or use company resources outside the workplace.

2.4 Acceptable Use

Users must use NexusTech technology primarily for legitimate business activities and in a manner that supports the organization's security and business objectives.

Users must:

1. Use company systems only for authorized business activities and approved purposes.
2. Protect company devices assigned to them from unauthorized access.
3. Keep passwords, authentication information and other access credentials confidential.
4. Follow approved security policies, standards and procedures.
5. Report suspected security incidents, loss of devices or suspected unauthorized access promptly.
6. Use only authorized software and services for business activities.
7. Handle company and client information according to its sensitivity and applicable security requirements.
8. Lock or otherwise secure devices when leaving them unattended.
9. Use corporate email, internet and network resources responsibly.
10. Cooperate with legitimate security monitoring and investigations conducted by authorized personnel.

Employees should also exercise reasonable judgment when using company resources. Security responsibilities do not end simply because an employee is working remotely.

2.5 Prohibited Activities

Users must not use NexusTech systems, devices or networks for activities that could compromise security, violate laws or regulations, damage the company's reputation, or interfere with business operations.

The following activities are prohibited:

1. Downloading, installing or using unauthorized software on company devices.
2. Disabling or bypassing security controls without proper authorization.
3. Sharing passwords, authentication tokens or access credentials with other individuals.
4. Attempting to gain unauthorized access to systems, accounts or information.
5. Accessing information without a legitimate business need or appropriate authorization.
6. Using company systems to distribute malware or other malicious software.
7. Deliberately introducing security vulnerabilities into company systems.
8. Using company resources to conduct illegal activities.
9. Uploading sensitive company or client information to personal cloud storage or other unauthorized platforms.
10. Sharing confidential information through personal email or unapproved messaging services.
11. Using company resources to harass, threaten or discriminate against others.
12. Excessive personal use that negatively affects productivity, system performance or security.
13. Connecting unauthorized devices to corporate systems where such connection could introduce security risks.
14. Circumventing network restrictions or security monitoring without formal approval.

The prohibition on unauthorized software is particularly relevant to the current NexusTech situation because unauthorized downloads have already contributed to increased malware and compliance concerns.

2.6 Reasonable Personal Use

Limited personal use of NexusTech technology may be permitted where it does not interfere with work responsibilities, consume excessive resources, create security risks or violate any company policy.

Examples may include briefly checking personal email or carrying out a limited personal online activity during an appropriate break.

Personal use must not involve:

- Illegal activities
- Unauthorized software downloads
- Accessing inappropriate or malicious websites
- Storing sensitive company information in personal accounts
- Excessive use of company resources
- Activities that create security, legal or reputational risks.

NexusTech reserves the right to restrict personal use where it creates a material risk to the organization.

2.7 Roles and Responsibilities

Employees and Other Users

Users are responsible for understanding and complying with this policy. They must protect company resources, use technology responsibly and report suspected security incidents promptly.

IT and Information Security

IT is responsible for implementing appropriate technical controls that support the policy. Information Security is responsible for providing security guidance,

monitoring compliance where appropriate, supporting awareness activities and recommending policy improvements.

Managers

Managers are responsible for reinforcing the policy within their teams. They should ensure that employees understand their responsibilities and should escalate repeated or serious non-compliance.

Human Resources

HR should support the organization in communicating policy requirements to employees and managing disciplinary matters where policy violations require formal employee action.

2.8 Compliance and Enforcement

Compliance with this policy is mandatory.

NexusTech may monitor the use of company systems in accordance with applicable laws, regulations and internal requirements. Where a potential violation is identified, the matter may be investigated by the appropriate function.

Depending on the nature and severity of the violation, consequences may include additional training, restriction of access, formal disciplinary action, contract-related consequences or referral to relevant authorities where legally required.

Enforcement should be proportionate to the circumstances. Accidental misunderstanding should normally be addressed through clarification and

training, while deliberate or repeated violations should receive stronger escalation.

2.9 Exceptions

Exceptions may be granted where there is a legitimate business need and compliance with the policy would prevent an important business activity from being completed.

An exception request must:

- Explain the business reason for the exception.
- Identify the requirement being waived.
- Explain the security risk created by the exception.
- Identify compensating controls where appropriate.
- Be reviewed and approved by the appropriate authority.
- Have a defined expiry or review date.

Exceptions should be documented centrally so that they can be tracked and reviewed. This approach is consistent with the Week 2 material, which recommends justification, risk assessment, approval, time-limited exceptions and regular review.

2.10 Policy Review and Approval

The Information Security Manager owns this policy and is responsible for coordinating its review and maintenance.

The policy will be submitted to the appropriate management authority for approval. The CEO, Marcus Vance, is the designated approval authority for Version 1.0.

The policy should be reviewed at least annually and earlier where there are significant changes to technology, business operations, regulatory requirements, security risks or security incidents.

EVIDENCE BUNDLE 3: USER ACCESS REQUEST PROCEDURE

Task 3: User Access Request Procedure

3.1 Purpose

The purpose of this procedure is to ensure that access to NexusTech systems and information is formally requested, properly approved, provisioned according to business need and documented for future review.

The procedure addresses the current problem where the Helpdesk receives informal requests through email or chat. The new approach creates a consistent process and reduces the likelihood of excessive or unauthorized permissions.

3.2 Scope

This procedure applies to Helpdesk personnel and other authorized personnel involved in creating, modifying or removing user access to NexusTech systems.

It applies to new employees, existing employees requiring additional access, employees changing roles and users whose access needs to be removed.

3.3 Prerequisites

Before processing an access request, the Helpdesk should have access to:

- The approved access request/ticketing system
- The user's identity and employment information
- The user's manager
- Applicable system or data owners

- Approved role/access profiles
- Existing access records where applicable.

Access must not be provisioned based solely on an informal email, instant message or verbal request.

3.4 Procedure

Step 1 – Receive the Request

Receive the access request through the approved ticketing or workflow system. Confirm that the request identifies the user, requested system, required role and business reason.

Step 2 – Check the Request

Review the request for completeness. If important information is missing, return it to the requester for clarification rather than proceeding with incomplete information.

Step 3 – Verify Manager Approval

Confirm that the user's manager has approved the requested access. The approval should be recorded in the approved workflow or attached to the ticket.

Step 4 – Verify Data or System Owner Approval

Where access involves sensitive systems or information, confirm approval from the relevant system or data owner.

Step 5 – Confirm the Appropriate Role

Determine which approved role or access profile best matches the user's job responsibilities. Access should be based on business need rather than convenience.

Step 6 – Apply Least Privilege

Check that the requested permissions provide only the level of access necessary for the employee to perform their duties. Do not provide administrator or elevated privileges unless there is a documented and approved requirement.

Step 7 – Create or Modify the Account

Create the account or modify the existing account using the organization's approved access-management process. Technical configuration details should be maintained in the appropriate technical procedure rather than this governance procedure.

Step 8 – Validate the Access

Confirm that the correct system, role and permission level have been assigned. Where appropriate, a second authorized person should verify higher-risk access.

Step 9 – Notify the User and Manager

Notify the user that access has been provisioned. The manager should also receive confirmation where appropriate.

Step 10 – Capture Evidence

Record relevant evidence in the access ticket, including approvals, requested role, completed action and date of completion.

Step 11 – Close the Ticket

Once all required checks have been completed, close the ticket and ensure the final status clearly shows that the access request was completed.

3.5 Emergency Requests

Emergency access may be granted when delaying access would create a significant operational or security problem.

However, emergency access must still be authorized by an appropriate person and documented. The access should be limited to what is necessary for the emergency and reviewed afterwards.

Any emergency access should be removed or adjusted when it is no longer required.

3.6 Exceptions

Where the requested access does not fit an approved role, the Helpdesk should not simply grant the access. The request should be escalated to the appropriate manager, data owner or security authority for review.

The exception and its approval should be recorded in the ticket.

3.7 Record Retention and Audit Trail

Access requests, approvals and completion evidence should be retained in accordance with NexusTech's records-retention requirements.

The audit trail should allow the organization to answer basic questions such as:

- Who requested the access?
- Who approved it?
- What access was requested?
- Why was it required?

- Who provisioned it?
- When was it provisioned?
- Was the access appropriate?

This creates accountability and provides useful evidence during internal reviews, audits and investigations.

EVIDENCE BUNDLE 4: COMMUNICATION AND TRAINING PLAN

Task 4: Policy Implementation and Communication

Simply sending employees a PDF would not be enough to ensure that the AUP is understood and followed.

Audience	Key Message	Communication /Training Channel	Owner	Timing	Acknowledgement	Success Measure
General Employees	Company systems must be used responsibly. Unauthorized software, inappropriate use and storing sensitive information on personal cloud accounts are prohibited.	All-hands session, email, intranet and mandatory online training	Information Security & HR	Week 1	Electronic policy acknowledgement	At least 95% training completion and acknowledgement
IT/Helpdesk Staff	User access must be requested and approved through the formal workflow. Informal requests through email or chat must not be used to provision access.	Management briefing and discussion session	Information Security & HR	Week 1	Manager attestation	At least 95% attendance and acknowledgement

New Employees	Security responsibilities begin from the first day of employment, including responsible use of company systems and protection of company information.	Induction training and onboarding module	HR & Information Security	Ongoing	Onboarding attestation	100% completion within the onboarding period
Senior Management	Management support is essential for reinforcing compliance and addressing repeated or serious policy violations.	Executive briefing	Information security manager	Launch Week	Management confirmation	Evidence of management sponsorship and timely escalation

4.2 Rollout Timeline

Day 1 – Announcement

The CEO announces the new policy framework and explains why NexusTech is changing its approach. The message should focus on protecting company and client information and creating consistent security practices.

Days 2–3 – Policy Communication

The AUP is distributed through the intranet and email. Employees are directed to the mandatory learning module.

Days 3–5 – Training

Short training sessions are conducted for employees, managers and IT staff. The sessions should focus on practical examples rather than simply reading the policy word for word.

End of Week 1 – Acknowledgement

Employees complete an electronic acknowledgement confirming that they have read, understood and agreed to comply with the policy.

Week 2 – Knowledge Check

Employees complete a short knowledge assessment covering key requirements such as unauthorised software, personal cloud storage, reporting security incidents and responsible use of company devices.

Weeks 3–4 – Follow-up

Information Security reviews completion rates, common questions, failed knowledge checks and reported issues. Areas where employees appear confused should receive additional clarification.

4.3 Measuring Effectiveness

Two important measures will be used initially:

1. Training and Acknowledgement Rate

The organisation should track the percentage of employees who complete the required training and formally acknowledge the AUP.

2. Knowledge-Check Performance

Employees should complete a short assessment. A high completion rate alone does not prove understanding, so knowledge-check results should also be reviewed.

Additional measures can include:

- Number of AUP violations;
- Number of unauthorised software incidents;
- Number of exceptions requested;
- Number of repeated policy violations;
- Employee questions or feedback;
- Security incidents linked to inappropriate use.

These measures reflect the course material's emphasis on compliance, incidents, awareness, exception tracking and risk reduction as indicators of policy effectiveness.

4.4 Escalation of Non-Compliance

Not every policy mistake should immediately result in disciplinary action. Where an employee misunderstands a requirement, the first response should normally be clarification or additional training.

However, repeated or deliberate non-compliance should be escalated.

A reasonable escalation path is:

1. First occurrence/misunderstanding → clarification or refresher training
2. Repeated issue → manager involvement and formal warning where appropriate
3. Serious or deliberate violation → HR and Information Security investigation
4. Severe case → formal disciplinary action or other appropriate escalation

This approach creates a balance between enforcement and education. It also recognizes that the purpose of a security policy is not simply to punish employees but to establish secure and consistent behavior.

EVIDENCE BUNDLE 5: POLICY REVIEW AND MAINTENANCE

MEMO

Task 5: Policy Review Memo

To: Information Security Steering Committee

From: Information Security Manager

Subject: Review and Update of Acceptable Use Policy

Date: 17th September, 2026.

The Acceptable Use Policy should be formally reviewed following two significant developments at NexusTech. First, the organization has migrated its primary database to AWS. This represents a major change to the technology environment and may change how employees interact with company information and cloud-based resources. The AUP should therefore be checked to ensure that its requirements remain relevant to the new environment. Second, an employee shared a sensitive document through a personal cloud storage account. Although the incident was minor, it demonstrates that the existing policy needs clearer guidance around personal cloud services, unauthorized data storage and the handling of sensitive information. These developments meet the practical need for an early policy review rather than waiting for the next scheduled review.

The review should involve Information Security, IT, relevant business owners, HR, Legal/Compliance and representatives of affected user groups. The review team should examine the incident, current access and cloud-use practices, previous policy exceptions, training feedback and other available evidence. A risk assessment should then determine whether the existing controls remain adequate. I recommend that the revised AUP specifically prohibit storing or sharing sensitive company or client information through personal cloud accounts and require approved corporate cloud services to be used for business information. The policy should also clarify acceptable use of cloud services and

employee responsibilities when working remotely. The Information Security Manager should remain the policy owner, with the revised policy submitted to Marcus Vance, CEO, for approval. Following approval, the policy should be reviewed annually, with an early review triggered by major technology changes, significant security incidents, material regulatory changes or repeated policy violations.

Conclusion

The NexusTech scenario demonstrates why a structured security policy framework is important as an organization grows. The company's previous "IT Rules" document combined policies, standards, guidelines and procedures into one document, making it difficult for employees to understand what was mandatory and what was simply recommended. The proposed hierarchy separates these documents according to their purpose and level of detail.

The Acceptable Use Policy provides employees with clear rules for using company systems and devices, while avoiding unnecessary technical instructions. The User Access Request Procedure then translates access-control requirements into a practical sequence that Helpdesk personnel can follow consistently. This distinction is important because the Week 2 material emphasizes that policies establish requirements while procedures operationalize them.

The communication and training plan also recognizes that publishing a policy does not automatically result in compliance. Employees need to understand the reasons behind the requirements, know what is expected of them and have an opportunity to ask questions. Training completion, acknowledgement and knowledge-check results provide evidence that the rollout is actually reaching employees.

Finally, the policy should not be treated as a document that is written once and forgotten. The AWS migration and personal-cloud incident show why policy maintenance is necessary. Regular reviews, combined with early-review triggers, allow NexusTech to respond to changes in technology, business activities and security threats. This supports the broader objective of creating a security governance framework that remains practical and useful as the organization continues to grow.

Overall, the proposed framework gives NexusTech a clearer line between management requirements, mandatory technical expectations, recommended practices and operational instructions. It also establishes accountability, communication, exception handling and continuous review. These are important foundations for strengthening information security governance and supporting the organization's readiness for frameworks such as ISO/IEC 27001 and SOC 2.

References

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements*. <https://www.iso.org/standard/27001>

International Organization for Standardization. (2022). *ISO/IEC 27002:2022 – Information security, cybersecurity and privacy protection – Information security controls*. <https://www.iso.org/standard/75652.html>

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. U.S. Department of Commerce. <https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20>